

IMMEDIATE PRIORITIES

Focus: Stop bots, prevent unauthorized access, and secure current credentials.

1. Bot Protection (CAPTCHA)

User Story

As a Super Admin and Admin-Owner, I want the login page to verify that the user is human without annoying them, so that our system is not overwhelmed by automated credential stuffing attacks.

Purpose: To filter out 99% of automated bot traffic before it even hits your database authentication logic.

Technical Solution

- **Integration:** Implement **Google reCAPTCHA v3** (Invisible mode). Do not use "Select all traffic lights" puzzles unless the risk score is high.
- **Logic:**
 - On Login Page Load: Execute invisible challenge.
 - On Submit: Send token to backend.
- **Backend Verify:** If token score is low (bot likely), reject login immediately.

2. Adaptive Lockout & Secure Password Reset

User Story

As a User (all users), I want to reset my password securely if I forget it. I want the system to verify it is really me via a code sent to my phone *before* letting me change my credentials.

Purpose: To prevent "Account Takeover" via weak reset flows and stop brute-force guessing.

Technical Solution

- **Lockout Logic (Exponential Backoff):**
 1. Track failed_attempts in Redis (key: login_fail:{ip}:{email}).
 2. **Threshold:** If > 5 attempts, enforce a time delay (1 min, 5 min, 15 min) before checking the password again.

2-Step Reset Flow:

3. **Step 1:** User enters Email.
4. **Step 2:** System checks if phone_number exists.
 - If yes: Send 6-digit SMS code. User must enter code to proceed.
 - If no: Fallback to Email Link (less secure, but necessary if no phone).
1. **Step 3:** Generate short-lived JWT (10 mins) allowing the password change form to load.
2. **Notification:** Send email: "Your password was changed. If this wasn't you, click here to lock account."

3. Multi-Factor Authentication (MFA)

User Story

As an Admin, I require a second form of verification (Code) to log in. I want the option to trust my office computer so I don't have to enter a code every single morning.

Purpose: The single most effective control against stolen passwords.

Technical Solution

- **Provider:** Integrate Twilio (SMS).
- **Add Trigger Rules:**
 - Always on new IP/Device fingerprint.
 - Every 30 days for Trusted Devices.
 - Mandatory for Admins; **Conditional** for Clients (on unusual activity).

4. Geo-Blocking & Concurrent Sessions

User Story

As the Super Admin and Admin-Owner, I want to ensure staff cannot log in from outside the US, and that no user can have multiple open sessions that could be exploited.

Technical Solution

- **Middleware:** Check IP Country. If != US, block (Admins) or Force MFA (Clients).
- **Session Killer:** On new login, find existing sessions for user_id in database and set expires_at = NOW().